

Axiom AI Technologies

Information Security Management System Management Review Report

Document Reference: AAX-MR-2026-001

Version: 1.0

Document Status: Approved – Portfolio Case Study

Classification: Internal Use

Organization: Axiom AI Technologies

Review Period: October 2026

Document Owner: ISMS Owner

Framework Owner: Security Governance / GRC

Approval Authority: Executive Management

Next Scheduled Review: October 2027

Document Control

Field	Details
Document Title	Information Security Management System Management Review Report
Document Reference	AAX-MR-2026-001
Version	1.0
Classification	Internal Use
Document Owner	ISMS Owner
Framework Owner	Security Governance / GRC
Approval Authority	Executive Management
Review Frequency	At least annually
Effective Date	October 2026
Next Review	October 2027
Status	Approved – Portfolio Case Study

1. Executive Summary

This management review evaluates the continuing suitability, adequacy, and effectiveness of the Axiom AI Technologies Information Security Management System (ISMS).

The review consolidates information from the organization's risk-management, control-assessment, ISMS implementation, business-continuity, vulnerability-management, security-remediation, and compliance activities.

The assessment indicates that Axiom AI has established a functioning information-security governance foundation supported by documented policies, risk-management processes, business-continuity planning, vulnerability management, incident response, security remediation, and compliance monitoring.

The review identified several opportunities for improvement, primarily involving:

- Centralization of governance decisions and management actions.
- Formalization of control ownership.
- Consistency of security-objective measurement.
- Standardization of operational evidence collection.
- Strengthening of recurring access reviews.
- Improvement of centralized logging and monitoring evidence.
- Formalization of compliance-obligation tracking.
- Establishment of recurring compliance validation.
- Strengthening of evidence-handling procedures.
- Continued validation of data-security controls.

No critical or high-risk compliance findings were identified during the simulated assessment.

The management review therefore concludes that the ISMS is **generally suitable and adequate**, with targeted improvements required to strengthen consistency, evidence maturity, governance oversight, and continual improvement.

2. Purpose

The purpose of this management review is to provide executive-level evaluation of the Axiom AI ISMS and determine whether it remains:

- Suitable for the organization's business and risk environment.
- Adequate to address identified information-security requirements and risks.
- Effective in achieving established security objectives.
- Supported by appropriate resources and governance.

- Capable of continual improvement.

The review also establishes management decisions and actions required to address identified weaknesses and improve the overall maturity of the ISMS.

3. Scope

The management review covers the Axiom AI Technologies ISMS and supporting cybersecurity processes within the defined ISMS scope.

The review considers:

- Information-security governance
 - Risk management
 - Security objectives
 - Security policies
 - Control effectiveness
 - Compliance
 - Internal assessment
 - Vulnerability management
 - Security remediation
 - Incident response
 - Security monitoring
 - Business continuity
 - Disaster recovery
 - Third-party risk
 - Security awareness
 - Data security
 - Resource requirements
 - Continual improvement
-

4. Management Review Inputs

The following information was considered during the review.

Input	Source	Review Result
Organizational context	ISMS Scope Statement	Suitable
Security governance	Security Governance Framework	Improvement opportunity
Risk profile	Risk Register	Acceptable with monitoring
Control effectiveness	Controls Assessment	Improvement required
ISMS documentation	ISMS documentation set	Generally adequate
Business continuity	BIA / BCP / DRP	Suitable
Vulnerability management	Vulnerability Management Program	Effective with ongoing remediation
Security remediation	Remediation Register	Ongoing
Incident response	Incident Response Policy / Tabletop	Effective
Compliance	Compliance Assessment	55% compliant / 45% partially compliant
Security metrics	KPI/KRI reporting	Improvement required
Internal assessment	Internal Assessment Program	Improvement required
Third-party risk	Third-Party Risk Management	Ongoing
Security awareness	Training records	Adequate
Data security	Data-security controls	Improvement required

5. Changes in Internal and External Issues

The management review considered changes that could affect the ISMS.

5.1 Internal Changes

Relevant internal considerations include:

- Continued development of cloud-based AI/ML services.
- Expansion of security governance processes.
- Increasing reliance on cloud infrastructure and SaaS providers.
- Growth in the volume and importance of customer and business data.
- Increased integration between security, engineering, operations, and compliance activities.
- Continued maturation of the ISMS.

5.2 External Changes

Relevant external considerations include:

- Increasing cybersecurity threats targeting cloud services.
- Growing regulatory expectations concerning privacy and AI systems.
- Increasing customer expectations for security assurance.
- Changes in third-party and cloud-service risk.
- Continued development of cybersecurity standards and regulatory requirements.
- Increased use of AI technologies and associated security considerations.

Management Conclusion

The ISMS remains relevant to the organization's current environment.

No changes were identified that require immediate modification of the ISMS scope. However, governance, compliance monitoring, and data-security processes should continue to mature alongside organizational and technological changes.

6. ISMS Performance and Effectiveness

6.1 Overall Assessment

The ISMS demonstrates a functioning governance foundation with established processes for:

- Risk management
- Policy management
- Access control
- Incident response
- Vulnerability management
- Business continuity
- Security remediation
- Compliance assessment
- Security governance

The primary weakness is not the absence of security processes but the consistency and maturity of evidence demonstrating their ongoing operation and effectiveness.

6.2 Management Assessment

Area	Assessment
ISMS suitability	Suitable
ISMS adequacy	Adequate
ISMS effectiveness	Generally effective
Governance maturity	Developing
Risk management maturity	Established
Compliance maturity	Developing
Evidence maturity	Developing
Business continuity maturity	Established
Vulnerability-management maturity	Established
Continual improvement	Developing

7. Compliance Assessment Results

The October 2026 compliance assessment evaluated 40 requirements across ISO/IEC 27001:2022 and supporting NIST CSF 2.0 requirements.

Result	Count	Percentage
Compliant	22	55%
Partially Compliant	18	45%
Non-Compliant	0	0%
Not Applicable	0	0%
Under Review	0	0%

Management Interpretation

The results indicate that Axiom AI has implemented a substantial baseline of security governance and operational controls.

The 18 partially compliant requirements primarily relate to process consistency, evidence maturity, recurring validation, governance documentation, and monitoring rather than complete absence of controls.

Management should therefore prioritize **maturity and consistency improvements** rather than wholesale control implementation.

8. Risk Management Review

The risk-management process was reviewed using the established risk register and associated treatment activities.

Key areas reviewed included:

- Risk identification
- Risk analysis
- Risk scoring
- Risk ownership
- Treatment planning
- Residual-risk evaluation
- Risk acceptance
- Monitoring

The current risk-management process is considered **established and effective**.

Management Observations

Management should continue to ensure that:

- Risk owners remain clearly assigned.
- Risk assessments are refreshed periodically.
- Material changes trigger reassessment.
- Risk treatment actions are tracked through closure.
- Residual risks are explicitly documented.
- Accepted risks have appropriate management approval.

Decision

Continue the existing risk-management framework with increased emphasis on treatment tracking and recurring reassessment.

9. Security Objectives and Performance

Security objectives were reviewed using available KPI and KRI information.

Key performance areas include:

- Vulnerability remediation
- Security incidents
- Compliance status
- Access-review completion
- Security awareness
- Risk-treatment progress
- Business continuity readiness
- Security-control effectiveness

Management Observation

The security-objective framework is established, but performance measurement should become more consistent.

Improvement Actions

1. Assign an accountable owner to every security objective.
2. Define consistent reporting frequencies.
3. Establish measurable target values.
4. Track trends rather than isolated measurements.
5. Escalate missed objectives when risk thresholds are exceeded.

Decision

Strengthen the security-metrics framework during the next review cycle.

10. Security Governance Review

The Security Governance Framework establishes the relationship between:

- Executive Management
- ISMS Owner
- Security/GRC
- Security Operations
- Control Owners
- Risk Owners

- Internal Assessment

The governance model is considered appropriate for the organization's size and operating environment.

Improvement Opportunity

Governance decisions and actions should be centralized into a formal governance decision/action register.

This will improve:

- Accountability
- Traceability
- Evidence quality
- Executive oversight
- Action tracking
- Audit readiness

Decision

Establish a centralized governance decision and action log.

Target Date: January 31, 2027

Owner: Executive Management / ISMS Owner

11. Vulnerability Management and Security Remediation

The vulnerability-management process was reviewed as part of the management review.

The process includes:

- Vulnerability identification
- Risk classification
- Prioritization
- Remediation
- Validation
- Residual-risk tracking

Security remediation activities are integrated with the risk-management process.

Management Assessment

The vulnerability-management capability is considered **established**.

Continued focus should be placed on:

- Remediation timeliness
- Recurring vulnerabilities
- Root-cause analysis
- Evidence of remediation validation
- Management escalation of overdue high-priority findings

Decision

Continue risk-based vulnerability management and monitor remediation performance through security KPIs.

12. Security Incident Management

Incident-response capabilities were reviewed using the documented incident-response process and tabletop-exercise results.

The process includes:

- Incident identification
- Initial triage
- Classification
- Escalation
- Response
- Evidence handling
- Communications
- Recovery
- Lessons learned

The tabletop exercise demonstrated the organization's ability to coordinate response activities across relevant functions.

Management Assessment

Incident-response capability is considered **effective**, with continued improvement required around evidence handling and centralized documentation.

Decision

Continue periodic incident-response exercises and formalize evidence-handling requirements.

13. Business Continuity and Disaster Recovery

Management reviewed:

- Business Impact Analysis
- BCP/DR Strategy
- Disaster Recovery Plan
- Recovery Runbooks
- RTO requirements
- RPO requirements
- Tabletop exercise results

The continuity program establishes:

Recovery Time Objective (RTO): ≤ 4 hours

Recovery Point Objective (RPO): ≤ 24 hours

The recovery strategy and associated runbooks provide a defined framework for responding to significant technology disruptions.

Management Assessment

Business continuity and disaster-recovery capabilities are considered **established**.

Decision

Continue periodic testing and ensure that recovery exercises validate:

- RTO achievement
 - RPO achievement
 - Recovery dependencies
 - Communications
 - Decision-making
 - Escalation procedures
-

14. Third-Party Risk Management

Third-party security remains an important component of the Axiom AI risk environment because the organization relies on external cloud, SaaS, infrastructure, and technology providers.

Management reviewed:

- Supplier-security assessments
- Security questionnaires
- Contractual requirements
- Risk classifications
- Remediation activities
- Critical supplier dependencies

Management Assessment

The third-party risk-management process is established but should continue to mature through consistent evidence collection and periodic reassessment.

Decision

Maintain risk-based supplier assessment and prioritize critical suppliers for recurring review.

15. Access Control

Access-management findings were reviewed as part of the compliance assessment.

The primary improvement area is the consistency of evidence supporting periodic access reviews.

Required Improvements

- Establish formal access-review frequency.
- Assign review ownership.
- Document review results.
- Track exceptions.
- Retain evidence.
- Validate removal of unnecessary access.

Decision

Implement recurring access certification with documented evidence.

Target Date: February 28, 2027

Owner: IT / Security

16. Logging and Monitoring

Security monitoring capabilities exist across relevant cloud and technology environments.

However, management identified an opportunity to improve:

- Centralized monitoring evidence
- Review documentation
- Alert-trend analysis
- Evidence retention
- Management reporting

Decision

Improve centralized monitoring and evidence management.

Target Date: May 31, 2027

Owner: Security Operations

17. Compliance and Regulatory Oversight

The compliance assessment identified a need for more formalized tracking of legal, regulatory, contractual, and policy requirements.

Management should maintain a centralized compliance-obligations register containing:

- Requirement
- Source
- Applicability
- Responsible owner
- Review frequency
- Evidence
- Status

- Related controls
- Corrective actions

Decision

Establish and maintain a formal compliance-obligations register.

Target Date: March 31, 2027

Owner: Legal / Security/GRC

18. Internal Assessment and Audit

The internal-assessment capability is defined but requires greater consistency in scheduling and evidence.

Management identified the following improvement:

- Establish an annual internal-assessment schedule.
- Define assessment scope.
- Document findings.
- Assign corrective actions.
- Validate remediation.
- Report significant results to management.

Decision

Establish a formal annual internal-assessment program.

Target Date: May 31, 2027

Owner: Internal Audit / ISMS Owner

19. Resource Requirements

Management reviewed whether current resources are sufficient to maintain the ISMS.

Resource categories considered include:

- Security personnel

- GRC resources
- Security tooling
- Cloud-security capabilities
- Compliance support
- Training
- Vulnerability remediation
- Business continuity
- Monitoring

Management Conclusion

Current resources are considered sufficient for maintaining the baseline ISMS.

Additional resources may be required as:

- Regulatory requirements expand.
- Security monitoring requirements increase.
- The technology environment grows.
- Customer assurance requirements increase.
- Compliance obligations become more complex.

Decision

Continue monitoring resource requirements through the annual management-review cycle and escalate material resource gaps when identified.

20. Continual Improvement Opportunities

The following improvement opportunities were identified:

Improvement	Priority	Owner	Target
Centralize governance decisions	Moderate	ISMS Owner	Jan 2027
Formalize control ownership	Moderate	ISMS Owner	Feb 2027
Strengthen access reviews	Moderate	IT / Security	Feb 2027
Establish compliance obligations register	Moderate	Legal / GRC	Mar 2027
Improve security-objective measurement	Moderate	ISMS Owner	Mar 2027
Standardize operational evidence	Moderate	Security Operations	Mar 2027
Strengthen evidence handling	Moderate	Security Operations	Apr 2027
Improve data-security validation	Moderate	Security / Privacy	Apr 2027
Improve security metrics and trends	Moderate	ISMS Owner	Apr 2027
Improve centralized monitoring evidence	Moderate	Security Operations	May 2027
Establish annual internal audit schedule	Moderate	Internal Audit	May 2027

21. Management Decisions

Based on the information reviewed, management makes the following decisions:

Decision 01 — ISMS Suitability

The ISMS remains suitable for the current Axiom AI organizational and technology environment.

Decision: Approved.

Decision 02 — ISMS Adequacy

The ISMS provides an adequate baseline of governance and security controls.

Decision: Approved with planned improvements.

Decision 03 — ISMS Effectiveness

The ISMS is generally effective, but evidence consistency and recurring validation should improve.

Decision: Continue operation with corrective actions.

Decision 04 — Risk Management

The current risk-management process remains appropriate.

Decision: Continue existing framework.

Decision 05 — Compliance

Compliance monitoring requires increased formalization.

Decision: Establish centralized compliance tracking and recurring validation.

Decision 06 — Governance

Governance decision tracking should be centralized.

Decision: Implement governance decision/action register.

Decision 07 — Business Continuity

Current BCP/DR capabilities are adequate for the defined requirements.

Decision: Continue periodic testing.

Decision 08 — Security Improvement

Management supports the identified continual-improvement actions.

Decision: Track actions through completion and effectiveness validation.

22. Management Action Register

Action ID	Action	Owner	Priority	Target Date	Status
MR-001	Establish governance decision/action register.	ISMS Owner	Moderate	2027-01-31	Open
MR-002	Complete formal control-owner mapping.	ISMS Owner	Moderate	2027-02-28	Open
MR-003	Implement recurring access certification.	IT / Security	Moderate	2027-02-28	Open
MR-004	Establish compliance-obligations register.	Legal / GRC	Moderate	2027-03-31	Open
MR-005	Improve security-objective measurement.	ISMS Owner	Moderate	2027-03-31	Open
MR-006	Standardize operational evidence collection.	Security Operations	Moderate	2027-03-31	Open
MR-007	Formalize evidence-handling procedures.	Security Operations	Moderate	2027-04-30	Open
MR-008	Strengthen data-security validation.	Security / Privacy	Moderate	2027-04-30	Open
MR-009	Improve KPI/KRI trend reporting.	ISMS Owner	Moderate	2027-04-30	Open
MR-010	Improve centralized monitoring evidence.	Security Operations	Moderate	2027-05-31	Open
MR-011	Establish annual internal-assessment schedule.	Internal Audit	Moderate	2027-05-31	Open

23. Follow-Up and Validation

Management actions shall be tracked through completion.

An action should not be considered fully closed solely because the assigned task was completed.

Closure should require:

1. Completion of the planned action.
2. Supporting evidence.
3. Review by the appropriate control or process owner.
4. Validation that the action addressed the original issue.
5. Documentation of the closure decision.

Where an action does not effectively address the identified issue, additional corrective action should be assigned.

24. Overall Management Review Conclusion

Based on the information reviewed, management concludes that the Axiom AI Technologies ISMS is:

Suitable: Yes

Adequate: Yes, with planned improvements

Effective: Generally effective

The ISMS provides a functioning foundation for managing information-security risks and supporting organizational objectives.

The primary improvement focus for the next review period should be **maturity, consistency, evidence quality, and governance oversight**.

Management supports continuation of the current ISMS while requiring the identified improvement actions to be tracked through completion and validation.

25. Next Management Review

The next formal management review is scheduled for:

October 2027

An earlier management review may be initiated following:

- A significant security incident
- Material organizational change
- Major technology change
- Significant regulatory change
- Major audit finding
- Significant change in risk exposure
- Material change to the ISMS scope

26. Approval

Role	Name / Function	Decision	Date
Executive Management	Executive Management	Approved	October 2026
ISMS Owner	ISMS Owner	Prepared / Recommended	October 2026
Security/GRC	Security Governance / GRC	Reviewed	October 2026

27. Revision History

Version	Date	Description	Author
1.0	October 2026	Initial management review report	ISMS Owner

Portfolio Disclaimer

Axiom AI Technologies is a fictional organization created for portfolio demonstration purposes.

This management-review report, including its findings, metrics, decisions, actions, dates, and supporting information, is simulated and is not presented as an actual management review of a real organization.

The case study is inspired by and based on real professional cybersecurity, GRC, ISMS, compliance, risk-management, and business-continuity practices.